
BADI SOC

A bilingual platform a security operations centre both runs a shift in and trains on, with governance joined to the daily work.

AUTHOR

Badi Saeed Alosaimi
Blue Team / SOC analyst — eCIR, eJPT

DATE

19 September 2026

STATUS

Working build, not deployed

What a centre actually loses time to

01 / 07

01

Triage without context

An L1 opens an alert and then opens four other tools to decide whether it matters.

02

Escalation by message

Context is retyped into chat or email, and the audit trail ends there.

03

Reporting after the fact

The report is rebuilt by hand from memory and screenshots, days later.

04

Training somewhere else

Analysts drill in a tool that behaves nothing like the one they work in.

05

Compliance as a separate file

ECC evidence is re-entered by hand, disconnected from the incidents that prove it.

06

Arabic bolted on

A translated skin over an English tool, with reversed addresses and blank strings.

One interface, two modes, four roles

02 / 07

Twelve screens serve an L1 triaging a queue, an L2 building an incident timeline, an L3 reviewing ATT&CK coverage, and a manager reading analyst performance and compliance. A toggle in the header switches the same screens between training and live work.

Training mode

Answers from a seeded dataset of 50,000 Windows events, with teaching hints on the elements an analyst is learning to read.

Live mode

Sends indicators to real threat-intelligence providers. Where a lookup cannot be made, the screen says so before the reader reads the number.

The interface never presents a dataset figure in the same treatment as a live one. An earlier build did, and it was corrected deliberately — a security tool that overstates its own certainty is worse than one that admits a gap.

01

Governance joined to the work

Thirty NCA ECC controls across five domains sit in the same database as the alerts and incidents. Compliance is read from operational records, not re-entered.

02

Genuinely bilingual

English default, Arabic one click away, flipping strings and direction. The API returns translation keys rather than prose, so errors render in the reader's language. Latin runs inside Arabic are bidi-isolated, on screen and on paper.

03

Every screen exports a report

Twelve screens, twelve printable reports carrying what was on screen, with a cover and correct direction in both languages. No screenshot step.

04

It states what it does not know

A missing key or a failed lookup produces a marked notice, not a confident number. Provenance is part of the interface.

What is built today

12 Screens, each with loading, error and empty states	51 API operations, authenticated on every data endpoint	50,000 Seeded Windows events	216 Automated tests — 136 backend, 80 frontend — plus an end-to-end suite
---	---	--	---

AREA	BUILT	STATE
Alert triage	20 alerts across five severities, auto-triage verdict, escalation with 26 recorded handovers	Working
Investigation	10 incidents, a timeline, indicator enrichment with per-source provenance, and the raw log lines behind every alert	Working
Playbooks	6 playbooks, step-tracked, each run tied to the incident it was run for	Working
MITRE ATT&CK	31 techniques across 12 tactics, coverage computed from real incident mappings	Working
NCA ECC	30 controls in 5 domains, with an Arabic-correct export	Working
Attack replay	3 timed scenarios, graded server-side, with the answer key withheld until the analyst has answered	Working
Threat intelligence	VirusTotal, AbuseIPDB and AlienVault OTX — all three verified answering on 19 September 2026	Working
Assistant	Google Gemini, given a live snapshot of this centre's own records, and instructed to decline what is not in it	Working

What is not built yet

05 / 07

A reviewer's time is better spent on the gaps than on the claims, so they are stated here rather than found.

SIEM connector	"Live" refers to live threat intelligence, not a live telemetry feed. The 50,000 events are seeded. Ingesting from Splunk, Sentinel or QRadar is the largest remaining piece of work.	Not built
Authentication, currently off	Implemented on every data endpoint and switched off by a documented build-time flag while the product is finished. Start-up refuses it against a non-local database and warns on every boot. It goes back on before any deployment.	Switched off
User administration	Adding or disabling an analyst means editing a source file and reseeding. All eleven accounts share one development password, and there is no audit trail of who changed what.	Not built
Shared SLA targets	Targets drive the queue markers correctly but are stored per browser. There is no server endpoint to share one set across a centre.	Partial
Attack replay depth	Three scenarios exist against the six originally specified.	Partial
Shift handoff, compliance log	Implemented but unexercised — no records generated against them yet.	Untested
Deployment	Runs under Docker Compose on one machine. No hosting, TLS termination, backup schedule or SSO.	Not built
VirusTotal licence	The free tier is licensed for non-commercial use. Demonstration is within it; deployment inside an organisation needs a paid contract, costed separately.	Commercial

Frontend

Next.js 14 App Router, TypeScript strict with no any, Tailwind over a single token file, Zustand. Colour is declared once and enforced by a lint rule in CI.

Backend

FastAPI, SQLAlchemy 2.0 async, PostgreSQL with Alembic migrations. Identity and role derive from the JWT server-side and are never trusted from a request body.

Verification

136 backend tests, 80 frontend unit tests, Playwright end-to-end, a design lint that fails the build, and a CI job that builds the schema from an empty database.

Accessibility is measured, not asserted: every text and background pair in the palette was computed against WCAG AA, and the weakest pair in the product measures 4.6:1 against a 4.5:1 requirement.

What a deployment would require

07 / 07

Infrastructure

A Linux host or container platform, managed PostgreSQL, TLS termination, a backup schedule.

Identity

An identity provider for single sign-on, replacing the built-in accounts.

Telemetry

A connector to whichever SIEM is already in place. The data model is ready for it; the connector is not written.

Licensing

A commercial VirusTotal contract. The other two intelligence sources and the assistant are usable as configured.

Nothing in the architecture blocks any of these. None of them is built, and the brief accompanying this deck says so in the same words.